

bentley-openflows brief

Bentley OpenFlows Firmware Attack Surface & Detection Brief

Scope: Research-only brief — firmware extraction is pending and no Bentley OpenFlows installer payloads are yet present in `firmware-staging/Bentley/`. Covers 7 product lines (OpenFlows SCADAConnect, OpenFlows WaterSight, OpenFlows WaterGEMS, OpenFlows SewerGEMS, OpenFlows StormCAD, OpenFlows WaterCAD, OpenFlows HAMMER) across 4 architecture classes. Findings combine Bentley CONNECT-Security advisories, CISA ICS advisories, NVD CVE records, and named research from Claroty Team82, Forescout Vedere Labs, and Dragos. Hash count: 0 (analyst queue priming only). **Water-utility relevance is the entire point of this brief:** Bentley OpenFlows is exclusively water/wastewater, and the SCADAConnect bridge promotes Bentley from "modeling tool" to "in-band OT participant" — the exact niche Iranian Cyber Av3ngers (Aliquippa PA, 2023-2024) and Volt Typhoon (CISA AA24-038A pre-positioning, 2024) actively occupy. Low CVE attention combined with high target priority is the worst kind of attack surface.

Purdue layer mapping: Group A (SCADAConnect) sits at **Purdue L3.5 (IT/OT Boundary)** — the data bridge between the modeling EWS and live SCADA. Group B (WaterSight cloud-edge dashboard) lives at **Purdue L3 (Site Operations)** with L4/L5 cloud egress. Group C (modeling tools — WaterGEMS / SewerGEMS / StormCAD / WaterCAD / HAMMER) lives at **Purdue L3 (EWS)** on the engineer/integrator laptop — the supply-chain pivot surface. Group D (ProjectWise integration layer, where deployed) is **Purdue L3 EWS**. See [purdue-l1-basic-controllers-brief.md](#) (downstream PLCs/RTUs the SCADA layer ultimately drives), [purdue-l2-area-supervisory-brief.md](#) (lift-station HMIs), [purdue-l3-site-operations-brief.md](#) (modeling EWS + control center), [purdue-l35-it-ot-boundary-brief.md](#) (SCADAConnect + WaterSight cloud agent), and [purdue-safety-systems-brief.md](#) for chlorine/chemical-dosing interlocks that hydraulic-model tampering can mislead operators about.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. SCADA-to-Model Bridge	L3.5 IT/OT Boundary	OpenFlows SCADAConnect	Windows service + OPC DA/UA client + OLEDB/ODBC adapters + SCADA-vendor connectors	research-only (pending)

Class	Purdue layer	Products	Stack	Catalog depth
			(AVEVA InTouch, GE Vernova Proficy iFIX, Inductive Automation Ignition, Siemens WinCC)	
B. Operations Dashboard	L3 Site Operations + L4/L5 cloud	OpenFlows WaterSight	.NET on-prem connector + HTTPS egress to Bentley iTwin / Azure cloud + Power BI embedded	research-only (pending)
C. Hydraulic Modeling EWS	L3 EWS	OpenFlows WaterGEMS, SewerGEMS, StormCAD, WaterCAD, HAMMER	Windows desktop + MicroStation/iModel shared parsers + Haestad legacy code + Python scripting + ESRI ArcMap/ArcGIS Pro add-in	research-only (pending)
D. Content Management (where deployed)	L3 EWS	ProjectWise integration (WaterGEMS/SewerGEMS share parsers with ProjectWise)	Windows service + IIS + SQL Server backend + DGN/DWG/iModel parser stack	research-only (pending)

Group A — OpenFlows SCADAConnect — Purdue L3.5 (IT/OT Boundary)

Direct attack surface (per Bentley SCADAConnect deployment guide):

OPC DA / OPC UA client (TCP/4840 UA, DCOM RPC for legacy DA) ·
 Direct SCADA-vendor connectors (AVEVA SuiteLink TCP/5413, GE Vernova Proficy iFIX iClientTS, Inductive Automation Ignition SQL Server / Historian read-back (TCP/1433) · ODBC tag pull ·
 Windows service running as SYSTEM with persistent credentials to every connected SCADA

SCADAConnect is, by design, a **dual-homed service**: it speaks the modeling-EWS protocol upstream to WaterGEMS and the SCADA protocol downstream to the production control system. The threat-model collapse is that its credential vault holds OPC/SuiteLink/Proficy iFIX credentials for the live SCADA — compromise of SCADAConnect equals "Valid Accounts" inside the production SCADA, with no exploit required.

Confirmed CVEs / advisories:

CVE / Advisory	Severity	Product	Vector	Status
Bentley CONNECT-Security advisories — OpenFlows / SCADAConnect class	Track per PSIRT	SCADAConnect	Service / connector class — track via PSIRT	Bentley CONNECT-Security advisories
Bentley shared-parser advisory family (MicroStation/iModel codepath)	Vendor-tracked	OpenFlows products bundling Bentley View / iModel parsers	XML/DGN/iModel parsing → memory corruption / RCE	Bentley CONNECT-Security advisories
Water-utility threat-actor TTP (no specific CVE — TTP family)	—	Production SCADA reachable via SCADAConnect creds	Pivot via legitimate integration path	CISA AA24-038A — Volt Typhoon water utility pre-positioning

Top attack vector (MITRE ATT&CK ICS): [T0859 Valid Accounts](#) — steal cached OPC/SuiteLink credentials from the SCADAConnect service account → log in to the production SCADA the same way SCADAConnect does every five seconds — chained to [T0836 Modify Parameter](#) via the now-authenticated OPC write path. No exploit chain required, which is exactly why this surface deserves the most scrutiny.

Group B — OpenFlows WaterSight — Purdue L3 Site Operations + L4/L5 cloud

Direct attack surface (per Bentley WaterSight deployment guide):

On-prem WaterSight connector (Windows service) • HTTPS/443 outbound to *.bentley.com / iTwin platform •
 Azure AD / Bentley CONNECT identity federation • embedded Power BI tiles •
 Pulls from PI / Historian / SCADAConnect upstream (read-mostly, but write-back optional)

WaterSight is the situational-awareness pane operators look at on a wall mount during an event.

The threat is [T0832 Manipulation of View](#): a falsified dashboard during an active attack convinces the operator nothing is wrong, buying the attacker dwell time inside the production SCADA.

Confirmed CVEs / advisories:

CVE / Advisory	Severity	Product	Vector	Status
Bentley CONNECT-Security advisories — WaterSight / iTwin connector class	Track per PSIRT	WaterSight	Connector / cloud-bridge class	Bentley CONNECT-Security advisories
Power BI embedded XSS / token-handling family	Vendor-tracked	WaterSight embedded tiles	Reflected XSS in dashboard chrome	Track Microsoft Security Response Center for Power BI advisories
Volt Typhoon water-utility pre-positioning TTPs	—	Cloud-egress credential abuse path	Cloud-token theft from the on-prem connector	CISA AA24-038A

Top attack vector (MITRE ATT&CK ICS): [T0832 Manipulation of View](#) via tampered dashboard tiles; secondary [T0866 Exploitation of Remote Services](#) against the on-prem connector itself.

Group C — Hydraulic Modeling EWS (WaterGEMS / SewerGEMS / StormCAD / WaterCAD / HAMMER) — Purdue L3 EWS

Direct attack surface (per Bentley product documentation + shared MicroStation parser stack):

Windows desktop application • DGN / DWG / iModel / WTG / SWMM / EPANET file parsing •
 Python scripting console (WaterGEMS) • ESRI ArcMap/ArcGIS Pro add-in (DLL load) •
 Bentley CONNECT Client (license + cloud sign-in) • ProjectWise integration (where deployed)

The Group C surface is dominated by **parser advisories inherited from the Bentley View / MicroStation / iModel codebase** (the OpenFlows products embed the same DGN/iModel parsers). The shared-parser family is the reference: Bentley View XML / DGN / iModel parsing → memory corruption. The supply-chain pivot is delivery of a malicious `.wtg` / `.dgn` / `.swmm` to an engineer or integrator who opens it in WaterGEMS — same threat model as malicious Solid Edge / SolidWorks files in the AEC threat model, but the engineer who opens it has SCADAConnect credentials cached on the same laptop.

Confirmed CVEs / advisories:

CVE / Advisory	Severity	Product	Vector	Status
Bentley View / MicroStation shared-parser family	Vendor-tracked	Bentley View XML / DGN / iModel parser (shared with OpenFlows products)	Out-of-bounds read/write → RCE via crafted file	Bentley CONNECT-Security advisories
Bentley OpenFlows family advisories	Track per PSIRT	WaterGEMS / SewerGEMS / WaterCAD / HAMMER	Parser / scripting console class	Bentley CONNECT-Security advisories
MicroStation / iModel parser long-tail	Vendor-tracked	All OpenFlows products bundling the iModel SDK	Recurring DGN/iModel parser advisories across 2020-2025	CISA ICS advisories index
Bentley CONNECT Client sign-in / federation class	Vendor-tracked	All OpenFlows products	Federated identity / token-replay class	Bentley CONNECT-Security advisories

Top attack vector (MITRE ATT&CK ICS): [T0865 Spearphishing Attachment](#) delivering a crafted `.wtg` / `.dgn` to a water-utility engineer → [T0866 Exploitation of Remote Services](#) via parser RCE → [T0859 Valid Accounts](#) abuse of SCADAConnect credentials cached on the same EWS.

Group D — ProjectWise integration layer — Purdue L3 EWS

ProjectWise (Bentley's CDE / content management product) is the document store many municipal water authorities use to version-control WaterGEMS models. Where deployed, it sits next to the modeling EWS and shares parser code with WaterGEMS/SewerGEMS. ProjectWise has a long history of authentication-class advisories — track via [Bentley CONNECT-Security advisories](#). Compromise of ProjectWise = ability to push a tampered hydraulic model into every engineer's check-out next morning, which is the supply-chain version of the Group C parser-CVE path.

Top attack vector (MITRE ATT&CK ICS): [T0862 Supply Chain Compromise](#) — replace the trusted hydraulic model in ProjectWise; every check-out is a delivery vehicle.

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	Sysmon on the SCADAConnect host	EventID 1 ProcessCreate where ParentImage is the SCADAConnect service AND child is <code>cmd.exe / powershell.exe / rundll32.exe</code>	Service-account abuse / credential dumping	T0859 Valid Accounts
2	Windows Security on SCADAConnect host	EventID 4624 Type 3 logon from SCADAConnect host into production SCADA outside the normal polling cadence	Pivot through the bridge	T0859 Valid Accounts
3	Network IDS (Suricata/Zeek)	OPC UA / SuiteLink (TCP/5413) / Proficy iFIX iClientTS write traffic originating from a non-SCADAConnect host	Direct exploitation of the trust path	T0866 Exploitation of Remote Services
4	Network IDS	OPC UA <code>WriteValue</code> from SCADAConnect outside the configured tag-write window (SCADAConnect is read-mostly in standard deployments)	Bridge weaponized as write path	T0836 Modify Parameter
5	Sysmon on WaterGEMS / modeling EWS	EventID 7 (ImageLoad) on <code>WaterGEMS.exe / SewerGEMS.exe / HAMMER.exe</code> loading DLL from user-writable path	Parser-CVE exploitation chain (DLL search hijack tail)	T0866 Exploitation of Remote Services
6	Sysmon on modeling EWS	ProcessCreate where ParentImage=WaterGEMS/SewerGEMS/HAMMER AND child not in Bentley allow-list	Post-parser-CVE shell	T0866 Exploitation of Remote Services
7	WaterSight on-prem connector log	Cloud-egress authentication token refresh from a non-connector source IP	Cloud-token theft / replay	T0866 Exploitation of Remote Services
8	ProjectWise audit log	DGN/WTG check-in outside the engineering change-window for a model the on-call team did not edit	Supply-chain model tamper	T0862 Supply Chain Compromise

Secondary: Bentley CONNECT Client sign-in audit (federated identity events for engineer accounts); WaterGEMS Python scripting console history (`%APPDATA%\Bentley\WaterGEMS\ script trace`); ProjectWise audit DB for model check-in/out; SCADAConnect service log for connector errors that indicate cred rotation; SCADAConnect's persistent credential vault file (`%ProgramData%\Bentley\SCADAConnect\`) — treat as crown-jewel credential store under auditd/Sysmon FileCreate watch.

OT-native anomaly signals: Hydraulic-model setpoint that no longer matches the SCADA setpoint (model-vs-SCADA divergence is the canonical SCADAConnect health signal — its disappearance can also mean the SCADA side has been quietly rewritten); WaterSight dashboard tile that stops updating during an active event (mask-the-attack precursor, [T0832 Manipulation of View](#)); HAMMER transient-analysis run launched without a maintenance window (an attacker may use HAMMER to model a water-hammer attack before executing it on the real network — [T0879 Damage to Property](#) precursor).

Specific zero-day-ish concerns for your dataset

1. **SCADAConnect credential vault is the single highest-priority Bentley surface in a water utility.** The vault holds OPC/SuiteLink/Proficy iFIX credentials for the live SCADA; compromise = Valid Accounts in production with zero exploit. First field check on any Bentley site is the ACL and Sysmon coverage on `%ProgramData%\Bentley\SCADAConnect\`. The Cyber Av3ngers / Volt Typhoon threat model lives here.
 2. **Bentley shared-parser advisory family is under-tracked in OpenFlows-specific advisories.** OpenFlows products bundle the same XML/DGN/iModel parsers as Bentley View and MicroStation, so an advisory filed against "Bentley View" is also exploitable in WaterGEMS opening the same crafted file. Map every OpenFlows install to its bundled iModel SDK build and triage against [Bentley CONNECT-Security advisories](#).
 3. **Low CVE attention + high target priority = stale assumptions of safety.** OpenFlows-specific CVE history is sparse because the deployed base is small relative to AVEVA / GE Vernova / Schneider Electric — *not* because the code is more secure. Assume parser code paths in WaterGEMS/SewerGEMS/StormCAD/WaterCAD/HAMMER are essentially un-fuzzed by external researchers; spearphished `.wtg` / `.dgn` / `.swmm` files are an extremely plausible 2025-2026 initial-access path that few SOC's would catch.
 4. **HAMMER (transient analysis) is dual-use.** An attacker with Valid Accounts on an engineer's workstation can run HAMMER to model the exact pump-stop sequence that will cause a damaging water-hammer event before triggering it via the production SCADA. HAMMER-launch detection without a maintenance ticket is a high-signal precursor for [T0879 Damage to Property](#).
 5. **ProjectWise model tamper is the supply-chain version of the Group C threat.** Where ProjectWise is deployed, every engineer's morning check-out is a delivery vehicle. A single replaced model in ProjectWise hits every WaterGEMS install in the utility. Audit DGN/WTG check-ins against the engineering ticketing system and treat unexplained check-ins as a critical SOC alert.
-

Water-utility deployment pattern

A typical mid-sized US municipal water utility runs the production SCADA on AVEVA InTouch, GE Vernova Proficy iFIX, or Inductive Automation Ignition — and runs OpenFlows WaterGEMS (plus SewerGEMS for the wastewater side) on an engineering workstation in the utility's engineering office. **OpenFlows SCADAConnect is the bridge** that lets WaterGEMS pull live SCADA tag values to drive real-time / predictive hydraulic modeling, and WaterSight is the wall-mount situational-awareness dashboard the on-call operator watches. The threat-model anchor is unavoidable: Iranian Cyber Av3ngers compromised the Aliquippa PA Municipal Water Authority via a Unitronics PLC on the operations network in late 2023, and Volt Typhoon ([CISA AA24-038A](#), Feb 2024) explicitly pre-positioned in US water utility OT networks. **Bentley sits exactly where these actors live:** compromise the engineer's laptop via a spearphished `.wtg` (Group C parser advisory) → harvest the cached SCADAConnect credentials from the connected SCADAConnect host (Group A Valid Accounts) → write Modbus/OPC into the production SCADA the same way the legitimate integration does every five seconds → mask the operator view via tampered WaterSight tiles (Group B [T0832 Manipulation of View](#)). The TTX archetype maps cleanly: control-center compromise = WaterSight/SCADAConnect host; pump-station compromise = downstream Modbus/OPC writes the bridge unlocks (see [purdue-l1-basic-controllers-brief.md](#)); lift-station compromise = SewerGEMS-driven setpoint manipulation on the wastewater side; contractor-network pivot = malicious model delivered via ProjectWise or email attachment to a hydraulic-modeling consultant. Pair this brief with the L3.5 brief at [purdue-l35-it-ot-boundary-brief.md](#) for the bridge surface and the L3 brief at [purdue-l3-site-operations-brief.md](#) for the modeling EWS and dashboard layer.

Sources

- [Bentley CONNECT-Security advisories / PSIRT portal](#)
- [NVD CVE search — Bentley vendor](#)
- [CISA AA24-038A — PRC State-Sponsored Actors \(Volt Typhoon\) Pre-positioning in US Critical Infrastructure](#)
- [CISA — Cyber Av3ngers / Unitronics water utility advisory](#)
- [CISA ICS Advisories index](#)
- [CISA water and wastewater sector resources](#)
- [Claroty Team82 — ICS/OT research](#)
- [Forescout Vedere Labs — Research Labs](#)
- [Dragos — ICS threat intelligence blog](#)
- [Bentley OpenFlows product documentation](#)
- [MITRE ATT&CK for ICS — T0832 Manipulation of View](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [MITRE ATT&CK for ICS — T0859 Valid Accounts](#)

- [MITRE ATT&CK for ICS — T0862 Supply Chain Compromise](#)
- [MITRE ATT&CK for ICS — T0865 Spearphishing Attachment](#)
- [MITRE ATT&CK for ICS — T0866 Exploitation of Remote Services](#)
- [MITRE ATT&CK for ICS — T0879 Damage to Property](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)